

Passive Information Gathering (OSINT)

Module 2 — Reconnaissance · Unit 07

The first step of every assessment: learn about the target *before* you touch anything.

Learning objectives

By the end of this unit you can:

- **Place** recon in the attacker lifecycle: recon → scanning → exploitation → post-exploitation → reporting.
- **Tell apart** passive vs active information gathering.
- **Name and explain** 6+ OSINT sources.
- **Build** a Google "dork" with search operators.
- **Look up** WHOIS and DNS records and read what they reveal.
- **Extract** document metadata and explain the leak.
- **Audit** and shrink your own digital footprint.
- **Explain** the legal/ethical limits of OSINT — "it's public" ≠ "anything goes."

The attacker lifecycle

1. **Reconnaissance** ← we are here
2. Scanning
3. Exploitation
4. Post-exploitation
5. Reporting

Recon = the information-gathering phase. You can't attack — or defend — what you don't understand.

Passive vs active

	Passive (this unit)	Active (next unit)
Touches the target?	No	Yes — sends packets
Sources	Public records, third parties	The target's own systems
Example	Read a job posting	nmap a web server
Authorization	Still bound by law/ethics	Legally required

Passive recon collects information that is **already public**, without ever touching the target.

Six OSINT sources

- **WHOIS** — who registered a domain, and when.
- **DNS records** — the internet's phonebook (A, MX, NS, TXT, CNAME).
- **Search-engine "dorking"** — advanced operators to surface public pages.
- **Certificate transparency (CT)** — public TLS logs that leak hostnames.
- **Job postings** — leak the tech stack ("must know Apache, Cisco...").
- **Social media** — leaks people, roles, and habits.
- *(Plus: document metadata and breach-data awareness.)*

Domain & infrastructure: WHOIS + DNS

```
whois brightleafcoffee.example  
dig brightleafcoffee.example A  
dig brightleafcoffee.example MX  
dig brightleafcoffee.example NS
```

- **WHOIS:** registrar, registration/expiry dates, sometimes contacts (often redacted).
- **A** = address · **MX** = mail · **NS** = name servers · **TXT** = e.g., SPF.
- Redacted ≠ "nothing learned" — dates and registrar still help.

Subdomains & certificate transparency

- A **subdomain** is a name under the main domain: `mail.example.com`.
- **CT logs** are public records of every TLS certificate issued.
- They can reveal hostnames a company never advertised — like `dev.` or `vpn.`
- Each new host **expands the attack surface**.

The unadvertised `dev.` box is often weaker — and the most interesting find.

Google dorking

```
site:brightleafcoffee.example filetype:pdf  
site:brightleafcoffee.example intitle:"index of"  
"BrightLeaf" filetype:xlsx -site:brightleafcoffee.example
```

Operator	Does
<code>site:</code>	Limit to one domain
<code>filetype:</code>	Only that file type
<code>intitle:</code> / <code>inurl:</code>	Match the title / URL
<code>-</code>	Exclude · <code>" "</code> exact phrase

Metadata & breach awareness

```
exiftool sample-brochure.pdf
```

- **Metadata** = data about data: author, software + version, timestamps, GPS.
- `j.okafor` reveals a likely **username format**; software version is a **CVE lead** (preview of Unit 09).
- **Breach data** = awareness only. We do **not** download dumps or check others' emails.
- Takeaway: reused passwords are dangerous — motivates password managers.

Flip it: defend your own footprint

- Search **yourself** — see what the world sees.
- Tighten privacy settings on your own accounts.
- Strip metadata before posting photos/files.
- Use unique passwords (a manager helps).

Attackers profile you — so should you, to reduce your footprint.

Ethics & Authorization

"It's public" is NOT the same as "anything goes."

Passive recon rarely touches systems — but pointing it at a real person can cross into **stalking, harassment, privacy violations, or doxing.**

Where the line is

- **Doxing** = aggregating public facts about a real person (address, schedule, employer, family). Harmful and often **illegal** — no matter where each fact came from.
- Authorization and **scope** still apply, even to "just looking."
- In this unit we gather info **only** about the teacher-seeded fictional target or **our own** footprint. Never a real third party.

Discussion: every fact was individually public. Does combining them create something new and harmful? Where's the line between research and surveillance?

Key vocabulary

Term	Meaning
OSINT	Intelligence from publicly available sources
Passive recon	Gathering info without touching the target
Footprint	The public trail about a person/org
WHOIS	Public domain-registration record
DNS record	Name → address/service mapping
Dorking	Advanced search operators to find public info
CT log	Public TLS-cert log (leaks hostnames)
Metadata	Hidden "data about data" inside files
Attack surface	All points a target could be probed



Lab launch

Passive OSINT on an Authorized Target

Platform: browser-based (any laptop) + optional Kali (`whois`, `dig`, `exiftool`). A **TryHackMe** OSINT room is an approved alternative.

Targets: the teacher-seeded fictional persona/company **or your own footprint — only.**

Lab roadmap

- **Part A** — WHOIS, DNS, certificate transparency.
- **Part B** — Google dorks + tech-stack inference from a job posting.
- **Part C** — document metadata + your own footprint self-audit.
- **Deliverable** — a short, professional **mini OSINT report**: target, scope statement, sources, findings by source, and a defender "how to reduce exposure" section.

Write your **scope statement** at the top of your lab journal *before* you start.

Recap

- Recon is the first phase of the lifecycle — and a defender skill too.
- **Passive** = public sources, never touches the target. **Active** = next unit, needs authorization.
- OSINT sources: WHOIS, DNS, CT logs, dorking, job postings, social media, metadata.
- "It's public" ≠ ethical. Doxing is harmful and often illegal.
- Stay on the authorized target — every single day.

Exit ticket & discussion

Exit ticket: Give one example of passive recon and one of active recon — and say which one requires authorization.

Discuss: Every fact in a "dossier" was public on its own. Does combining them cross a line? Who decides?

Next up — Unit 08: Active Information Gathering & Scanning (we start sending packets).